

THE FORENSICS WAY

ISSUE 32

FORENSICS AWARENESS THIS WEEK

TUESDAY, SEPTEMBER 8, 2026

FRONT PAGE

AI-ENABLED ATTACKS

Ten Hours, Zero Humans: A Ransomware Crew Lets Frontier AI Agents Run the Entire Kill Chain — Then Leaves an 80-Page Audit Behind

Unit 42 documented an intrusion where a ransomware operator handed the entire attack to frontier AI models and an agentic framework, compressing a compromise that normally takes human operators about two weeks into under 10 hours. A reconnaissance agent mapped a public API endpoint and the internal microservices behind it; subagents then scraped code repositories for hardcoded tokens and passwords, used them to reach the organization's secret-management system, and extracted master administrative credentials for root access. Specialist "pivot agents" independently validated that access across cloud, identity, CI/CD, container, and SaaS environments before hijacking CI/CD workflows to steal cloud access keys and repurposing the victim's own cloud AI services as post-compromise infrastructure.

The attacker then left something no ransomware crew has bothered with before: an 80-page report, generated by an agent, cataloging dozens of exploited findings across the environment — reconnaissance-as-ransom-note. Forensic priority: review CI/CD workflow logs for anomalous cloud-key issuance events, audit the secret-management system's access trail for the exact path to the stolen master credential, treat any of the victim's own AI or cloud services showing unexpected activity as compromised infrastructure rather than merely accessed resources, and preserve the attacker's left-behind audit document itself — it maps their reconnaissance in near-total detail.

ZERO-DAY

No Patch, No Password: Magento's Payment-Reminder Email Becomes a Loading Dock for a Rust Backdoor

Sansec disclosed StyleSmuggler on September 4 — an unauthenticated remote-code-execution zero-day (CVE-2026-

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-83548 / CVE-2026-83549

SonicWall SMA1000 (models 6210, 7210, 8200v) — a pre-auth SSRF in the Work Place interface (CVSS 10.0) chains into an OS command-injection flaw in the Appliance Management Console, yielding unauthenticated RCE. INC Ransomware has become the most active group weaponizing the chain — the third SMA1000 zero-day incident in 2026 after July's CVE-2026-15409/15410. *Forensic Note:* Patch immediately, review Work Place and AMC access logs for SSRF-pattern requests, and treat every internet-facing SMA1000 as compromised until proven otherwise.

ACTIVE EXPLOIT

CVE-2026-9586

Sangoma Switchvox — a SQL injection flaw is being weaponized to deploy reverse shells and mint unauthorized administrative tokens. Added to CISA KEV this week. *Forensic Note:* Review Switchvox database query logs for injection patterns, audit admin-token issuance for unexplained new tokens, and hunt reverse-shell callback traffic from the appliance's host network.

MALWARE SPOTLIGHT

Manic — The Android Trojan That Steals Your PIN While the App Works Fine

Manic abuses Android Accessibility services to lay an invisible overlay on top of a targeted app's numeric keypad: it records each tap, then

75650, CVSS 10.0) affecting every current version of Magento Open Source and Adobe Commerce, including the newly released 2.4.9. The flaw abuses Magento's template system: an attacker injects PHP into the "Payment Transaction Failed Reminder" email template using the platform's own 'styles' properties to slip past detection, triggering code execution the moment the reminder email renders. Sansec reproduced the full unauthenticated attack chain on clean installs of 2.4.7 through 2.4.9 before a patch existed.

Two payloads have been observed in the wild: a Rust-based Linux backdoor phoning home to an external server, and a PHP dropper that writes a persistent web shell. Adobe's post-patch guidance is unusually severe — treat the site's encryption key as burned and rotate everything it protected: admin passwords, REST/SOAP/GraphQL tokens, OAuth client secrets, payment gateway API credentials, database credentials, SSH and deploy keys, and third-party extension API keys. Forensic priority: apply the VULN-39341 patch immediately, audit the Payment Transaction Failed Reminder template for injected 'styles' content, hunt outbound connections matching the Rust backdoor's C2 pattern, and search template and media directories for planted PHP web shells.

briefly passes the tap through to the real keypad, so the banking app functions normally while the PIN is silently captured. The same Accessibility-based keylogger classifies and captures passwords, SMS codes, crypto seed phrases, and lock-screen input across 169 monitored apps spanning banking, government eID, crypto, 2FA, and messaging services, mostly in Europe. When offline, it relays stolen data over Wi-Fi or Bluetooth to nearby infected devices, which forward it onward once connected. *Forensic Note:* Audit installed apps for unwarranted Accessibility service permissions, review Bluetooth/Wi-Fi Direct connection logs for peer-to-peer data transfers between unrelated devices, and treat any device that granted broad Accessibility access to a sideloaded app as compromised.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, SEPTEMBER 8, 2026

CASE STUDIES: HISTORICAL GRID

SQL SLAMMER (2003)

Ten Minutes to Global: The Worm That Proved a Machine Can Outrun Every Human Defender at Once

On January 25, 2003, a single 376-byte UDP packet exploiting an unpatched Microsoft SQL Server buffer overflow spawned a worm that doubled its infected population every 8.5 seconds, reaching an estimated 75,000 hosts worldwide in under 10 minutes — faster than any human incident response process could even

HEARTBLEED (2014)

The Bug That Made the Whole Internet Rotate Its Keys: OpenSSL's Memory-Disclosure Wake-Up Call

Disclosed in April 2014, Heartbleed was a buffer over-read in OpenSSL's heartbeat extension that let a remote, unauthenticated attacker read up to 64KB of a server's process memory per request — private keys, session tokens, and credentials included — from roughly two-thirds of the internet's HTTPS servers with no trace left in

be paged. SQL Slammer carried no payload beyond self-replication, yet its sheer propagation speed saturated internet backbones, knocked out ATMs, and delayed an airline's ticketing system, becoming the canonical proof that removing the human decision loop from an attack changes the physics of defense entirely. This week's AI-agent ransomware campaign is the same lesson two decades later: a two-week human intrusion compressed to 10 hours once the decision-making step is automated away.

server logs. Its aftermath introduced the now-familiar playbook this week's StyleSmuggler advisory echoes almost verbatim: patch first, then assume every key and credential the vulnerable process touched is burned and must be rotated, because the vulnerability itself leaves no reliable record of what was actually taken.

SYNFUL KNOCK (2015)

The Firmware That Wouldn't Show Itself: How FireEye Found a Persistent Backdoor Hiding Inside Cisco Routers

In September 2015, FireEye's Mandiant unit disclosed SYNful Knock, a modified Cisco IOS firmware image found on routers across four countries that gave attackers persistent, unauthenticated access surviving normal reboots — activated by sending crafted TCP SYN packets to the device, a covert command channel that left no obvious trace in standard configuration review. Because the backdoor lived in the firmware itself rather than in a running process, conventional endpoint detection had nothing to see, and only integrity checks against known-good firmware hashes exposed it.

LOG4SHELL (2021)

One Log Line, Total Compromise: How a String Formatter Became the Internet's Worst Zero-Day

In December 2021, researchers disclosed CVE-2021-44228 — Log4Shell — a flaw in the ubiquitous Java logging library Log4j where a single attacker-controlled log message containing a JNDI lookup string could trigger remote class loading and code execution, instantly weaponizable against millions of internet-facing Java applications with zero authentication required. The underlying lesson — that dynamically loading a class or resource based on untrusted input is inherently dangerous, no matter how deep in the application stack it happens — keeps resurfacing in new templating and class-loading engines years later.

TOOLS OF THE TRADE

OPEN SOURCE

ScoutSuite

NCC GROUP — V5.X

Multi-cloud security-auditing tool covering AWS, Azure, and GCP configuration and IAM posture. Run it post-incident against any environment touched by this week's AI-agent ransomware to map exactly what the stolen master credential and

OPEN SOURCE

MobSF

MOBILE SECURITY FRAMEWORK
— V4.X

Automated static and dynamic analysis framework for Android and iOS applications. Point it at a suspected Manic APK to map its Accessibility-service permissions, extract the 169-app target list, and trace the overlay-injection

COMMERCIAL

eComscan

SANSEC — V2026.09

Malware scanner purpose-built for Magento and Adobe Commerce storefronts, from the same researchers who discovered StyleSmuggler. Scans template files, media directories, and cron jobs for the Rust backdoor's

UTILITY / SCRIPT

osquery

OSQUERY COMMUNITY — V5.X

SQL-queryable endpoint telemetry framework for fleet-wide investigation. Query every Linux management host adjacent to an SMA1000 deployment in one pass for indicators of the SSRF-to-RCE chain, rather than triaging appliances one at a time.

hijacked CI/CD keys could reach.

logic without manual decompilation.

footprint and any planted PHP web shells before and after patching.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-65400 (APPLE MACOS SCREEN SHARING)

Improper-authentication flaw lets a remote attacker bypass credential checks for interactive Screen Sharing access; CVSS 9.8. CISA KEV. *Forensic Note:* Review Screen Sharing connection logs for unrecognized source IPs and confirm the current macOS security update is applied.

ARCHIVE ALERT

CVE-2026-8037 (PROGRESS KEMP LOADMASTER)

Unauthenticated remote command execution in the load balancer's management interface; 792 exploit attempts across 65 IPs logged before the KEV addition. *Forensic Note:* Inventory internet-facing LoadMaster management interfaces and treat any reachable instance as compromised until artifact review proves otherwise.

RECENT MALWARE WATCH

ARCHIVE: SEPTEMBER 1, 2026

NIMBUS MANTICORE — IRAN'S ESPIONAGE TOOLKIT GETS A NEW BACKDOOR

A TWOSTROKE-like backdoor and dedicated SSH tunneler expand the Iranian group's persistence options, blending with legitimate remote-administration traffic. Hunt unexpected outbound SSH tunnels from hosts with no administrative reason to run one.

ARCHIVE: AUGUST 25, 2026

AMNESIA STEALER — THE MACOS MALWARE THAT WATCHES YOU WORK

Harvests credentials from 16 Chromium browsers, iCloud Keychain, and crypto wallets, then opens a live Chrome DevTools Protocol screencast for real-time, attacker-driven session hijacking. Hunt unexpected processes holding open CDP debug ports.